

LEGAL–TECHNICAL FORENSIC REPORT

Operation Phantom Swipe — Cross-Border ATM & Credit-Card Fraud Ring

Unit 1: Foundations of Digital Forensics — Assignment 1

Examiner	[Your Name]	Case / FIR No.	[FIR No.]
Roll No.	[Roll No]	Date	[Date]
Course	[Course / Subject]	Institution	[University]
Classification	Confidential — LE use	Status	Early-phase investigation

Executive Summary

This report documents the early-phase digital-forensic investigation of an organised, cross-border payment-fraud ring operating between New Delhi, India, and Dubai, United Arab Emirates. Two exhibits were seized and examined: **EXH-01**, an ATM magnetic-stripe skimmer with a PIN-pad overlay, and **EXH-02**, an operator's Android smartphone. Forensic imaging was performed under write-blocking controls, and all 14 acquired files were fingerprinted with SHA-256 to establish an integrity baseline. A scripted examination recovered **19 artefacts** — including harvested card numbers (all Luhn-valid), intercepted OTPs, command-and-control and cryptocurrency identifiers, and geolocation data that ties the suspect device to the crime scenes. A password-protected vault of stolen card “dumps” was lawfully opened by a dictionary attack in **41 guesses** (0.0028s), the password having been weak and reused across the operation. The evidence establishes offences under the Information Technology Act, 2000, the Indian Penal Code, 1860, and conduct addressed by the Budapest Convention. The principal operational obstacle is the cross-border dimension, which this report analyses before recommending concrete improvements to law-enforcement standard operating procedures.

Scope, Authority and Limitations

This examination was conducted on two exhibits lawfully seized under a search authority and covers the early phase of the investigation: classification of the offences, integrity-preserving acquisition, an initial media search, and decryption of one protected container. It does **not** extend to live network capture, third-party server data (which requires separate legal process), or the tracing of proceeds beyond the wallet identifiers recovered on the devices. All findings are reproducible from the accompanying repository. As a simulated academic exercise, the dataset is fabricated: card numbers are the publicly published network **test** PANs, and every name, e-mail, phone number, wallet and coordinate is fictitious; nothing herein reflects real individuals or accounts.

1. Summary of Crimes and Digital Footprint

1.1 Nature of the offences

The scenario is a layered criminal enterprise rather than a single offence. Physical **ATM skimming** captured magnetic-stripe Track-1/Track-2 data together with PINs via an overlay keypad. That data enabled **card cloning** (the fabrication of counterfeit payment instruments) and **online / card-not-present fraud** using intercepted one-time passwords. The stolen data (“dumps”) was then **trafficked** to an overseas buyer through a darknet-linked mobile application, with proceeds routed to cryptocurrency wallets — an incipient **money-laundering** layer. The coordinated roles of installer, mules and buyer evidence a **criminal conspiracy** spanning two jurisdictions.

1.2 Digital footprint recovered

- Skimmer (EXH-01):** capture buffer with six harvested PANs and a PIN keylog; device configuration showing Bluetooth exfiltration to the operator phone; firmware whose carved strings reveal the C2 host, collector MAC, a Bitcoin wallet, and — critically — a DUMP_KEY reused as the vault password.
- Phone (EXH-02):** SMS backup showing OTP interception; a WhatsApp group (“PhantomSwipe”) coordinating cash-outs across Delhi and Dubai; a sideloaded carding app with C2 host, fallback IP and crypto wallets; a repackaged phishing banking app; an e-mail to the overseas buyer offering “20 fresh dumps”; and photo EXIF metadata plus a location history geolocating the device to the ATM sites and a Dubai cash-pickup point.

- **Protected vault (EXH-02):** an encrypted archive that, once opened, yielded a full card-dump CSV (PAN, expiry, CVV, holder, PIN), a buyer invoice, and a (dummy) wallet seed.

1.3 Reconstructed timeline

Date (2024)	Event	Supporting artefact
02 Nov	Skimming at HDFC Connaught Place ATM #112; 6 cards cloned; OTP intercepted for online purchase	captured_tracks.log; sms_backup.txt; IMG_2041 EXIF
03 Nov	Operations moved to Axis Bank Dubai Branch #07; further captures; cash-out coordination	whatsapp_chat.txt; photo_metadata.csv
04 Nov	Dumps packaged in vault.zip; e-mail to Buyer-DXB; crypto payment referenced	buyer_deal.eml; carderpro_config.json
05 Nov	Premises search; EXH-01 and EXH-02 seized and imaged	Chain-of-Custody form

A condensed statutory mapping is given in the Appendix; the full taxonomy and justification are in docs/01_Cybercrime_Taxonomy_and_Legal_Mapping.md.

2. Evidence-Handling Justification

Digital evidence is volatile and trivially altered; its evidentiary value depends entirely on demonstrable integrity and an unbroken chain of custody. The following controls were applied and are justified below.

2.1 Seizure and isolation

The exhibits were photographed *in situ* before removal. EXH-02 (the phone) was immediately placed in a **Faraday / RF-shielded bag** to sever cellular, Wi-Fi and Bluetooth connectivity, defeating remote-wipe and remote-lock commands that could destroy evidence. EXH-01 was bagged anti-static with its power state recorded. The **order of volatility** was respected — transient state captured before persistent storage.

2.2 Write-blocking and imaging

All analysis was performed on **working copies** acquired through a hardware **write-blocker**; the original media were never mounted read-write. This guarantees that examination cannot alter source evidence, preserving its authenticity for court.

2.3 Hashing and integrity (why SHA-256)

Each acquired file was hashed with **SHA-256** at acquisition, producing a verifiable manifest of 14 entries (hashes/SHA256SUMS.txt). A cryptographic hash is a tamper-evident seal: any single-bit change yields a completely different digest, so re-hashing before analysis and before submission proves the evidence is unchanged. SHA-256 is used in preference to the legacy MD5/SHA-1, which are considered collision-weak. Integrity can be re-verified at any time with `sha256sum -c`.

2.4 Admissibility of electronic records

Under Indian law, electronic records are admissible subject to a certificate under **Section 65B of the Indian Evidence Act, 1872** (now **Section 63 of the Bharatiya Sakshya Adhiniyam, 2023**), attesting to the manner of production and the reliability of the process. The write-blocked acquisition, contemporaneous hashing and the documented chain of custody together support such a certificate and rebut any allegation of tampering.

2.5 Chain of custody

Every transfer — from scene to custodian, to laboratory intake, to analysis, and back to secure storage — is logged with released-by / received-by identities, timestamps and purpose in the accompanying Chain_of_Custody_Form.pdf. Tamper-evident seals were applied and their numbers recorded, so any interference between transfers would be detectable.

3. Forensic Findings and Cryptography

3.1 Artefact recovery

A scripted string-search, metadata and e-mail examination catalogued **19 artefacts**. All recovered card numbers pass the **Luhn checksum**, confirming they are well-formed PANs rather than random digits. Geolocation from photo EXIF and location history independently corroborates the SMS/WhatsApp timeline across both countries, and the e-mail headers (including an originating IP) provide network-attribution leads.

The catalogue breaks down by category as follows:

Artefact category	Examples	Investigative value
Payment card numbers (PANs)	5 unique, all Luhn-valid	Victim identification; fraud-loss quantum
Intercepted OTPs / SMS	OTP 448190, 771020	Proves CNP fraud method
Geolocation (EXIF + history)	Delhi, Dubai, pickup point	Places device at scenes/times
C2 / darknet + IP	phantom-swipe.onion; 185.220.101.47	Infrastructure attribution
Crypto wallets	BTC + USDT-TRC20	Money-trail / proceeds tracing
Correspondents	buyer / operator e-mails	Links ring members across borders

3.2 Cryptography component — lawful decryption of the vault

The stolen dumps were sealed in a password-protected archive (ZipCrypto). A **dictionary attack** recovered the password cashout2024 in **41 guesses** in 0.0028 seconds. The archive fell almost instantly for two reasons: ZipCrypto is a weak legacy cipher, and the password was short, lowercase and **reused** — the same secret appears carved in the skimmer firmware and in the operator's notes. The equivalent industry workflow (zip2john → John the Ripper / hashcat) is provided as a reference script.

3.3 Ethics: brute-forcing vs. lawful decryption

Brute-force/dictionary decryption by investigators is lawful only within a valid search warrant or seizure authority and, ideally, a judicial direction; it must be limited to the seized evidence and fully logged. It is distinct from **compelled disclosure**, where the state issues a lawful **decryption request** to the suspect or a service provider. In India, Section 69 of the IT Act (with the 2009 Rules) empowers directions for decryption assistance; refusal is itself an offence. Compelling a suspect to surrender a password also raises the right against self-incrimination (Article 20(3) of the Constitution), so lawful-request routes are generally preferred where available and time permits, with investigator-side cracking reserved for evidence already lawfully in custody.

3.4 Reflection on password strength

This case illustrates a recurring reality: offenders reuse short, memorable passwords, which makes their own operational security their undoing. The same weakness that let investigators open the vault in milliseconds would let a criminal open a victim's. Strong, unique, high-entropy passphrases and modern authenticated encryption (e.g. AES-256) resist dictionary attacks; the observed reuse across firmware, notes and the vault is precisely the anti-pattern that both defenders and offenders are warned against.

4. Challenges in Cross-Border Investigation and Cooperation

The India–UAE dimension is the defining difficulty. Evidence, suspects and proceeds are distributed across jurisdictions with different legal systems, and several structural obstacles arise:

- **No Budapest Convention route.** India is **not a party** to the Convention on Cybercrime, so its expedited-preservation and 24/7-network mechanisms (Arts. 29–35) are unavailable. Cooperation must rely on bilateral **Mutual Legal Assistance Treaties (MLATs)** and **Letters Rogatory** under Sections 166A/166B of the CrPC (now the BNSS, 2023) — a process that routinely takes many months.
- **Foreign-held data.** Chat, e-mail (e.g. Proton) and app-server records sit with providers outside Indian jurisdiction; obtaining them needs provider-specific legal process and, often, US-style preservation letters.
- **Attribution behind anonymity.** Tor (.onion) C2 and disposable identifiers frustrate direct attribution and require correlation with seized-device evidence.
- **Cryptocurrency tracing.** Following proceeds demands blockchain analytics and cooperation from Virtual Asset Service Providers across borders, engaging the FATF **Travel Rule** and inconsistent VASP regulation.

- **Dual criminality and evidentiary standards.** MLA typically requires the conduct to be an offence in both states, and each may demand different chain-of-custody / certification standards for the same exhibit.
- **Time and volatility.** Cross-border latency clashes with short data-retention windows, so early **expedited preservation** requests are essential before formal MLA completes.

5. Recommendations for Law-Enforcement SOP Improvements

- **First-responder kit & checklist.** Mandate Faraday bags, hardware write-blockers and a seizure checklist so isolation and imaging are consistent from the first minute.
- **Hashing + certificate templates.** Require SHA-256 hashing at acquisition and attach a pre-formatted Section 63 BSA / 65B certificate to every electronic exhibit to secure admissibility.
- **Rapid preservation playbook.** Maintain ready-to-send expedited-preservation templates for major foreign providers and a roster of MLA points of contact to start the clock immediately.
- **Dedicated cyber-MLA cell.** Resource a specialised unit to draft and track Letters Rogatory / MLAT requests, and re-open the policy question of acceding to (or aligning with) the Budapest Convention.
- **Crypto-tracing capability.** Adopt blockchain-analytics tooling and formal VASP liaison channels to seize and trace proceeds, leveraging the FATF Travel Rule.
- **Bank / ATM partnership.** Establish an anti-skimming programme with issuers and operators (tamper alarms, regular inspections, rapid PAN-block on compromise) to shrink the harvesting window.
- **Training, tool validation & audit.** Certify examiners, validate forensic tools, and keep tamper-evident audit logs for every action on evidence.
- **Joint task forces.** Use INTERPOL I-24/7, Red Notices and joint India–UAE task forces to coordinate simultaneous action against distributed actors.

6. Conclusion

Operation Phantom Swipe demonstrates how foundational digital-forensic discipline — careful seizure, write-blocked imaging, SHA-256 integrity, and a rigorous chain of custody — converts a pile of seized hardware into court-ready evidence of a multi-jurisdiction fraud enterprise. The technical investigation is tractable; the binding constraint is cross-border cooperation. Closing that gap through faster preservation, stronger MLA capacity and proactive bank and VASP partnerships is where the greatest investigative return lies.

Appendix A — Condensed Statutory Mapping

Conduct	IT Act 2000	IPC 1860	Budapest
ATM skimming / interception	s.66 r/w s.43	s.378/379	Art. 2, 3
Card cloning (forgery)	s.66	s.463/465/468/471	Art. 4, 7
Identity theft (PAN/PIN/OTP)	s.66C	s.419	Art. 8
Online / CNP fraud, phishing app	s.66D	s.420	Art. 8
Trafficking dumps / device misuse	s.66B	s.411	Art. 6
Organised ring	—	s.120B r/w s.34	—

Appendix B — Tools Used

Python 3 (hashlib, zipfile, re, csv); coreutils sha256sum; Info-ZIP zip/unzip; John the Ripper / hashcat (reference workflow); ReportLab (report typesetting). Custom scripts: generate_evidence.py, hash_files.py, search_media.py, crack_zip.py, seal_vault.sh, crack_with_john.sh.

Appendix C — Authorship Declaration

I, **[Your Name]** ([Roll No]), declare that this report and the accompanying repository are my own work, produced for [Course/Subject] at [University]. All case data is simulated for academic purposes; card numbers are published network test values and no real personal or financial data was used. Sources and tools are acknowledged above.

